

Analisis Vulnerability Assessment dan Penetration Testing pada Website Ktown4u Menggunakan OWASP ZAP Berdasarkan Standar OWASP Top 10

Nayla Salsabila¹, Widi Afriza², Nadhirotus Syaima³

¹Program Studi Politeknik Informatika, Politeknik Purbaya

Abstrak

Perkembangan teknologi informasi telah meningkatkan penggunaan website sebagai media penyedia layanan dan transaksi secara daring. Seiring dengan meningkatnya penggunaan website, ancaman terhadap keamanan sistem juga semakin beragam, seperti *SQL Injection*, *Cross-Site Scripting (XSS)*, *Security Misconfiguration*, dan berbagai kerentanan lainnya yang dapat mengancam kerahasiaan, integritas, serta ketersediaan data. Oleh karena itu, pengujian keamanan website perlu dilakukan untuk mengidentifikasi potensi kerentanan sebelum dimanfaatkan oleh pihak yang tidak bertanggung jawab.

Penelitian ini bertujuan untuk menganalisis tingkat keamanan website Ktown4u menggunakan metode *Vulnerability Assessment* dan *Penetration Testing (VAPT)* dengan memanfaatkan OWASP ZAP sebagai alat pengujian serta mengacu pada standar OWASP Top 10 sebagai dasar analisis kerentanan. Tahapan penelitian meliputi pengumpulan informasi (*information gathering*), pemindaian kerentanan (*vulnerability scanning*), analisis hasil pengujian, pengelompokan kerentanan berdasarkan kategori OWASP Top 10, serta penyusunan rekomendasi perbaikan sesuai dengan tingkat risiko yang ditemukan.

Hasil penelitian diharapkan dapat memberikan gambaran mengenai kondisi keamanan website Ktown4u, mengidentifikasi potensi kerentanan yang terdapat pada website, serta menghasilkan rekomendasi perbaikan yang dapat dijadikan sebagai bahan evaluasi untuk meningkatkan keamanan sistem. Penelitian ini juga diharapkan dapat menjadi referensi bagi penelitian selanjutnya yang membahas keamanan website menggunakan metode *Vulnerability Assessment* dan *Penetration Testing*.

Kata Kunci: *Vulnerability Assessment*, *Penetration Testing*, OWASP ZAP, OWASP Top 10, Keamanan Website, Ktown4u.

BAB I

PENDAHULUAN

1.1 Latar Belakang

Perkembangan teknologi informasi telah membawa banyak perubahan dalam berbagai bidang kehidupan, salah satunya pada bidang perdagangan. Saat ini, kegiatan jual beli tidak lagi dilakukan hanya secara langsung, tetapi juga melalui website atau platform *e-commerce*. Kemudahan dalam mengakses informasi, melakukan pemesanan, hingga pembayaran secara daring membuat penggunaan website semakin meningkat. Di sisi lain, semakin banyaknya aktivitas yang dilakukan melalui website juga meningkatkan risiko terjadinya ancaman terhadap keamanan sistem.

Website yang digunakan sebagai media transaksi umumnya menyimpan berbagai data penting, seperti data pengguna, informasi akun, hingga data transaksi. Apabila sistem keamanan website tidak dikelola dengan baik, data tersebut berpotensi disalahgunakan oleh pihak yang tidak bertanggung jawab. Berbagai jenis serangan, seperti SQL Injection, Cross-Site Scripting (XSS), Cross-Site Request Forgery (CSRF), maupun kesalahan konfigurasi server, dapat menyebabkan kebocoran data, perubahan informasi, bahkan terganggunya layanan website. Oleh karena itu, pengujian keamanan perlu dilakukan secara berkala untuk mengetahui apakah masih terdapat celah keamanan yang dapat dimanfaatkan oleh penyerang.

Salah satu metode yang banyak digunakan untuk mengevaluasi keamanan website adalah *Vulnerability Assessment and Penetration Testing* (VAPT). *Vulnerability Assessment* dilakukan untuk mengidentifikasi dan menganalisis potensi kerentanan yang terdapat pada suatu sistem, sedangkan *Penetration Testing* bertujuan menguji apakah kerentanan tersebut dapat dieksploitasi dalam kondisi yang terkendali. Hasil dari kedua proses tersebut dapat menjadi dasar bagi pengelola website dalam melakukan perbaikan dan meningkatkan keamanan sistem.

Dalam pelaksanaannya, pengujian keamanan website sering mengacu pada standar OWASP Top 10 yang dikembangkan oleh *Open Worldwide Application Security Project* (OWASP). Standar ini berisi daftar kerentanan keamanan aplikasi web yang paling umum

ditemukan dan banyak digunakan sebagai pedoman dalam proses pengujian maupun penyusunan rekomendasi perbaikan. Dengan menggunakan standar tersebut, proses analisis dapat dilakukan secara lebih terarah dan sesuai dengan praktik keamanan aplikasi web yang berlaku.

Ktown4u merupakan salah satu website *e-commerce* yang menyediakan berbagai produk hiburan Korea Selatan, seperti album musik, *merchandise*, dan kebutuhan lainnya. Website ini digunakan oleh pelanggan dari berbagai negara sehingga mengelola berbagai aktivitas, mulai dari pendaftaran akun, pencarian produk, hingga proses transaksi. Sebagai website yang melibatkan banyak pengguna dan data transaksi, aspek keamanan menjadi hal yang penting untuk diperhatikan. Oleh karena itu, perlu dilakukan evaluasi keamanan untuk mengetahui apakah terdapat potensi kerentanan yang dapat memengaruhi keamanan website tersebut.

Beberapa penelitian sebelumnya menunjukkan bahwa penerapan metode VAPT mampu membantu mengidentifikasi berbagai kerentanan pada aplikasi web, seperti *Clickjacking*, *Sensitive Information Disclosure*, SQL Injection, dan Cross-Site Scripting (XSS). Hasil penelitian tersebut juga menunjukkan bahwa penggunaan standar OWASP Top 10 dapat memberikan gambaran mengenai tingkat keamanan website sekaligus menjadi dasar dalam menyusun rekomendasi perbaikan agar sistem menjadi lebih aman.

Berdasarkan uraian tersebut, penelitian ini dilakukan untuk menganalisis keamanan website Ktown4u menggunakan metode *Vulnerability Assessment and Penetration Testing* (VAPT) dengan mengacu pada standar OWASP Top 10. Penelitian ini diharapkan dapat memberikan gambaran mengenai kondisi keamanan website berdasarkan hasil pengujian yang dilakukan serta menghasilkan rekomendasi yang dapat digunakan sebagai bahan pertimbangan dalam meningkatkan keamanan website.

1.2 Rumusan Masalah

Berdasarkan latar belakang yang telah diuraikan, maka rumusan masalah dalam penelitian ini adalah sebagai berikut.

1. Bagaimana melakukan *Vulnerability Assessment* dan *Penetration Testing* pada website Ktown4u menggunakan standar OWASP Top 10?

2. Kerentanan keamanan apa saja yang ditemukan pada website Ktown4u berdasarkan hasil pengujian?
3. Bagaimana tingkat risiko dari setiap kerentanan yang ditemukan serta rekomendasi perbaikan yang dapat diberikan untuk meningkatkan keamanan website Ktown4u?

1.3 Batasan Masalah

Agar penelitian lebih terarah dan tidak menyimpang dari tujuan yang ingin dicapai, maka penelitian ini memiliki batasan sebagai berikut.

1. Objek penelitian adalah website Ktown4u yang dapat diakses secara publik.
2. Pengujian dilakukan menggunakan metode *Vulnerability Assessment and Penetration Testing* (VAPT).
3. Acuan pengujian menggunakan standar OWASP Top 10.
4. Pengujian hanya dilakukan terhadap bagian website yang dapat diakses tanpa melakukan tindakan yang merusak sistem, mengubah data, atau mengganggu layanan.
5. Hasil penelitian berupa identifikasi kerentanan, tingkat risiko, serta rekomendasi perbaikan berdasarkan hasil pengujian.

1.4 Tujuan Penelitian

Tujuan yang ingin dicapai dalam penelitian ini adalah sebagai berikut.

1. Melakukan analisis keamanan website Ktown4u menggunakan metode *Vulnerability Assessment and Penetration Testing* (VAPT).
2. Mengidentifikasi potensi kerentanan keamanan pada website Ktown4u berdasarkan standar OWASP Top 10.
3. Menganalisis tingkat risiko dari setiap kerentanan yang ditemukan.
4. Memberikan rekomendasi perbaikan sebagai upaya meningkatkan keamanan website Ktown4u.

1.5 Manfaat Penelitian

Penelitian ini diharapkan dapat memberikan manfaat sebagai berikut.

1. Manfaat Teoritis

Penelitian ini diharapkan dapat menambah wawasan dan referensi mengenai penerapan metode *Vulnerability Assessment and Penetration Testing* (VAPT) dalam pengujian keamanan website, khususnya dengan menggunakan standar OWASP Top 10.

2. Manfaat Praktis

a. Bagi Peneliti

Penelitian ini dapat menambah pengetahuan dan pengalaman dalam melakukan analisis keamanan website menggunakan metode VAPT.

b. Bagi Pengelola Website

Hasil penelitian diharapkan dapat menjadi bahan evaluasi terhadap keamanan website serta memberikan rekomendasi yang dapat dipertimbangkan untuk meningkatkan keamanan sistem.

c. Bagi Akademisi

Penelitian ini diharapkan dapat menjadi referensi bagi mahasiswa atau peneliti lain yang akan melakukan penelitian mengenai keamanan website dengan metode yang serupa.

BAB II

TINJAUAN PUSTAKA

2.1 Penelitian Terdahulu

Penelitian terdahulu digunakan sebagai referensi untuk mengetahui perkembangan penelitian mengenai keamanan website menggunakan metode Vulnerability Assessment and Penetration Testing (VAPT), OWASP ZAP, serta standar OWASP Top 10. Selain itu, penelitian terdahulu juga menjadi dasar dalam menentukan metode yang digunakan pada penelitian ini.

No	Penulis	Judul	Hasil
1	Rohmaniah dkk. (2024)	Enhancing Website Security Using VAPT	Menemukan 4 kerentanan keamanan
2	Zahrani dkk. (2024)	Analisis Vulnerability Assessment pada Sistem Informasi Website IITC Intermedia Universitas Amikom Purwokerto Menggunakan OWASP ZAP	Pengujian dilakukan menggunakan OWASP ZAP dengan tahapan scanning, analisis berdasarkan OWASP Top 10, dan penyusunan rekomendasi teknis.
3	Kishori & Muhammad Najib Dwi Satria (2025)	Vulnerability Analysis of SMAN 1 Banjar Agung Website Using OWASP ZAP	Ditemukan potensi kerentanan seperti SQL Injection, XSS, dan kelemahan konfigurasi keamanan melalui proses spider, passive scan, dan active scan.
4	Rakhmadi Rahman & Danang Fatkhur Razak (2024)	Pengujian Penetrasi Jaringan Menggunakan OWASP ZAP dan SQLMAP untuk Mengidentifikasi Kerentanan Keamanan Website	Berhasil mengidentifikasi kerentanan tingkat rendah dan sedang, terutama SQL Injection dan XSS.

5	Hifzul Wathoni Maulana, dkk. (2025)	Penetration Testing untuk Menguji Sistem Keamanan Website Menggunakan OWASP ZAP	Penelitian menunjukkan bahwa OWASP ZAP mampu mendeteksi parameter injection dan berbagai kerentanan pada website.
---	-------------------------------------	---	---

2.2 Landasan Teori

2.2.1 Website

Website merupakan kumpulan halaman yang saling terhubung dan dapat diakses melalui jaringan internet menggunakan web browser. Website digunakan sebagai media untuk menyampaikan informasi, menyediakan layanan, maupun melakukan transaksi secara daring. Seiring dengan perkembangan teknologi, website tidak hanya berfungsi sebagai media informasi, tetapi juga menjadi sarana komunikasi, pendidikan, bisnis, hingga perdagangan elektronik (e-commerce).

Berdasarkan fungsinya, website dapat dibedakan menjadi website statis dan website dinamis. Website statis memiliki isi yang relatif tetap dan hanya dapat diubah oleh pengembang, sedangkan website dinamis memungkinkan pengguna berinteraksi dengan sistem, seperti melakukan registrasi akun, login, pencarian produk, maupun transaksi secara daring. Karena website dinamis memproses data pengguna, aspek keamanan menjadi salah satu faktor yang sangat penting untuk diperhatikan.

2.2.2 Keamanan Website

Keamanan website merupakan upaya untuk melindungi aplikasi web beserta data yang dikelolanya dari berbagai ancaman maupun serangan siber. Tujuan utama keamanan website adalah menjaga kerahasiaan (confidentiality), keutuhan (integrity), dan ketersediaan (availability) data atau yang dikenal sebagai konsep CIA Triad.

Ancaman terhadap website dapat berasal dari berbagai jenis serangan, seperti SQL Injection, Cross-Site Scripting (XSS), Cross-Site Request Forgery (CSRF), Broken Access Control, Security Misconfiguration, hingga pencurian data pengguna. Serangan-serangan tersebut dapat menyebabkan kerugian bagi pemilik website maupun pengguna, seperti kebocoran informasi, manipulasi data, dan terganggunya layanan sistem.

2.2.3 Vulnerability Assessment

Vulnerability Assessment merupakan proses identifikasi, analisis, dan evaluasi terhadap kelemahan atau kerentanan yang terdapat pada suatu sistem informasi, aplikasi, maupun jaringan komputer. Tujuan dari proses ini adalah menemukan potensi celah keamanan yang dapat dimanfaatkan oleh penyerang sehingga dapat dilakukan perbaikan sebelum terjadi penyalahgunaan.

Dalam pelaksanaannya, Vulnerability Assessment dilakukan menggunakan berbagai teknik dan alat bantu yang mampu melakukan pemindaian terhadap sistem untuk menemukan konfigurasi yang kurang aman, penggunaan perangkat lunak yang memiliki kerentanan, maupun kesalahan dalam implementasi keamanan aplikasi.

2.2.4 Penetration Testing

Penetration Testing adalah metode pengujian keamanan yang dilakukan dengan mensimulasikan serangan terhadap suatu sistem secara terkontrol. Pengujian ini bertujuan untuk mengetahui apakah kerentanan yang telah ditemukan benar-benar dapat dieksploitasi oleh pihak yang tidak berwenang.

Tahapan Penetration Testing umumnya meliputi pengumpulan informasi (information gathering), identifikasi kerentanan, eksploitasi dalam batas yang diizinkan, analisis hasil, serta penyusunan laporan. Berbeda dengan Vulnerability Assessment yang hanya mengidentifikasi kerentanan, Penetration Testing memberikan gambaran mengenai dampak yang mungkin ditimbulkan apabila kerentanan tersebut berhasil dimanfaatkan oleh penyerang.

2.2.5 Vulnerability Assessment and Penetration Testing (VAPT)

Vulnerability Assessment and Penetration Testing (VAPT) merupakan metode yang digunakan untuk mengevaluasi tingkat keamanan suatu sistem informasi, aplikasi, maupun website. VAPT terdiri dari dua tahapan utama, yaitu Vulnerability Assessment dan Penetration Testing. Kedua tahapan tersebut saling melengkapi dalam proses pengujian keamanan.

Pada tahap Vulnerability Assessment, dilakukan identifikasi terhadap berbagai potensi kerentanan yang terdapat pada sistem. Setelah kerentanan berhasil diidentifikasi, tahap selanjutnya adalah Penetration Testing, yaitu melakukan simulasi serangan secara terkontrol untuk mengetahui apakah kerentanan tersebut benar-benar dapat dieksploitasi dan seberapa besar dampaknya terhadap sistem.

2.2.6 Open Worldwide Application Security Project (OWASP)

Open Worldwide Application Security Project (OWASP) merupakan organisasi internasional nirlaba yang berfokus pada peningkatan keamanan perangkat lunak, khususnya aplikasi berbasis web. Organisasi ini menyediakan berbagai panduan, dokumentasi, alat bantu, serta standar keamanan yang dapat digunakan oleh pengembang maupun peneliti dalam meningkatkan keamanan aplikasi.

Salah satu kontribusi terbesar OWASP adalah penyusunan OWASP Top 10, yaitu daftar sepuluh risiko keamanan aplikasi web yang paling umum ditemukan. Daftar tersebut diperbarui secara berkala sesuai dengan perkembangan ancaman keamanan siber sehingga menjadi salah satu acuan utama dalam proses pengujian keamanan aplikasi web.

2.2.7 OWASP ZAP

OWASP Zed Attack Proxy atau yang lebih dikenal sebagai OWASP ZAP merupakan aplikasi open source yang dirancang untuk membantu proses pengujian keamanan aplikasi web. Aplikasi ini dikembangkan oleh OWASP dan banyak digunakan oleh praktisi keamanan siber, peneliti, maupun mahasiswa karena memiliki antarmuka yang mudah dipahami serta menyediakan berbagai fitur pengujian.

OWASP ZAP mampu melakukan pemindaian otomatis (Automated Scan) maupun pengujian secara manual terhadap suatu website. Beberapa fitur yang tersedia antara lain Spider, Active Scan, Passive Scan, AJAX Spider, Fuzzer, dan pembuatan laporan hasil pengujian (Report Generation).

2.2.8 OWASP TOP 10

OWASP Top 10 merupakan daftar sepuluh risiko keamanan aplikasi web yang paling sering ditemukan berdasarkan hasil analisis dari berbagai organisasi dan praktisi keamanan di seluruh dunia. Daftar ini menjadi pedoman dalam proses identifikasi serta evaluasi kerentanan keamanan aplikasi web.

Adapun kategori kerentanan pada OWASP Top 10 (2021) meliputi:

1. Broken Access Control
2. Cryptographic Failures
3. Injection
4. Insecure Design
5. Security Misconfiguration
6. Vulnerable and Outdated Components

7. Identification and Authentication Failures
8. Software and Data Integrity Failures
9. Security Logging and Monitoring Failures
10. Server-Side Request Forgery (SSRF)

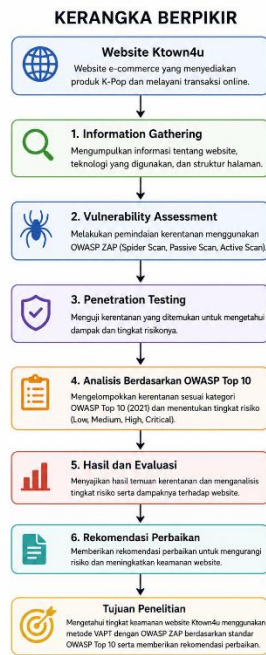
2.2.9 Website Ktown4u

Ktown4u merupakan platform e-commerce yang menyediakan berbagai produk hiburan Korea Selatan, seperti album musik, merchandise, lightstick, perlengkapan konser, serta berbagai produk resmi dari artis K-Pop. Website ini digunakan oleh pelanggan dari berbagai negara sehingga mendukung berbagai pilihan bahasa, metode pembayaran, dan layanan pengiriman internasional.

Sebagai website yang melayani banyak pengguna dan memproses data akun serta transaksi secara daring, aspek keamanan menjadi salah satu hal yang perlu diperhatikan. Oleh karena itu, website Ktown4u dipilih sebagai objek penelitian untuk mengevaluasi tingkat keamanannya menggunakan metode Vulnerability Assessment and Penetration Testing dengan bantuan OWASP ZAP serta mengacu pada standar OWASP Top 10.

2.2.10 Kerangka Berpikir

Kerangka berpikir penelitian ini menggambarkan alur analisis keamanan website Ktown4u menggunakan metode VAPT dengan bantuan OWASP ZAP dan acuan OWASP Top 10. Alur penelitian dimulai dari pengumpulan informasi terhadap website Ktown4u, kemudian dilakukan proses vulnerability assessment dan penetration testing menggunakan OWASP ZAP. Hasil pengujian selanjutnya dianalisis dan dikelompokkan berdasarkan kategori OWASP Top 10 sehingga diperoleh identifikasi kerentanan beserta tingkat risikonya. Berdasarkan hasil tersebut disusun rekomendasi perbaikan untuk meningkatkan keamanan website.



2.2.11 Kesimpulan Tinjauan Pustaka

Berdasarkan tinjauan pustaka yang telah dibahas, dapat disimpulkan bahwa metode Vulnerability Assessment and Penetration Testing (VAPT) merupakan pendekatan yang efektif untuk mengevaluasi keamanan website. OWASP ZAP dapat digunakan sebagai alat pengujian untuk mengidentifikasi potensi kerentanan, sedangkan OWASP Top 10 digunakan sebagai acuan dalam mengelompokkan dan menganalisis kerentanan yang ditemukan. Penelitian terdahulu juga menunjukkan bahwa kombinasi VAPT, OWASP ZAP, dan OWASP Top 10 mampu membantu proses identifikasi kerentanan serta penyusunan rekomendasi perbaikan keamanan website. Oleh karena itu, penelitian ini menggunakan metode tersebut untuk menganalisis keamanan website Ktown4u.

BAB III

METODOLOGI PENELITIAN

3.1 Metode Penelitian

Penelitian ini menggunakan metode Vulnerability Assessment and Penetration Testing (VAPT). Metode ini dipilih karena mampu mengidentifikasi potensi kerentanan keamanan pada website sekaligus mengevaluasi tingkat risikonya. Proses pengujian dilakukan menggunakan OWASP ZAP sebagai alat utama, sedangkan hasil pengujian dianalisis berdasarkan standar OWASP Top 10 (2021). Metode penelitian yang digunakan bersifat deskriptif, yaitu menggambarkan kondisi keamanan website berdasarkan hasil pengujian yang diperoleh.

3.2 Objek Penelitian

Objek penelitian adalah website Ktown4u yang merupakan platform *e-commerce* untuk penjualan album musik, *merchandise*, dan produk resmi K-Pop.

Website yang diuji merupakan halaman yang dapat diakses secara publik tanpa melakukan perubahan data maupun tindakan yang dapat mengganggu layanan website.

3.3 Alat dan Bahan Penelitian

Peralatan yang digunakan pada penelitian ini meliputi:

1. Perangkat Keras (Hardware)

- Laptop/PC
- Processor Intel Core i3 atau lebih tinggi
- RAM minimal 8 GB
- Koneksi internet

2. Perangkat Lunak (Software)

- Windows 10/11
- Google Chrome
- OWASP ZAP
- Microsoft Word
- Microsoft Visio atau Draw.io (untuk membuat diagram)

3.4 Teknik Pengumpulan Data

1. Studi Literatur

Mengumpulkan informasi dari buku, jurnal, artikel ilmiah, dan dokumentasi OWASP yang berkaitan dengan keamanan website, OWASP ZAP, VAPT, dan OWASP Top 10.

2. Observasi

Melakukan pengamatan langsung terhadap website Ktown4u untuk mengetahui fitur-fitur yang tersedia dan menentukan ruang lingkup pengujian.

3. Pengujian Website

Melakukan pengujian keamanan menggunakan OWASP ZAP untuk memperoleh data mengenai potensi kerentanan yang terdapat pada website.

3.5 Tahapan Penelitian

Tahapan penelitian terdiri dari beberapa langkah berikut.

1. Information Gathering

Tahap awal dilakukan dengan mengumpulkan informasi mengenai website Ktown4u, seperti struktur halaman, URL, teknologi yang digunakan, serta fitur yang tersedia.

2. Vulnerability Assessment

Pada tahap ini dilakukan proses pemindaian (*scanning*) menggunakan OWASP ZAP untuk mengidentifikasi potensi kerentanan keamanan.

Proses scanning meliputi:

- Spider Scan
- Passive Scan
- Active Scan

3. Penetration Testing

Setelah kerentanan ditemukan, dilakukan analisis terhadap hasil pengujian untuk mengetahui tingkat risiko masing-masing kerentanan tanpa melakukan eksploitasi yang dapat mengganggu layanan website.

4. Analisis Berdasarkan OWASP Top 10

Hasil scanning kemudian dikelompokkan berdasarkan kategori OWASP Top 10 (2021), seperti:

- Broken Access Control
- Cryptographic Failures
- Injection
- Security Misconfiguration

- Identification and Authentication Failures
- dan kategori lainnya yang relevan.

5. Penyusunan Rekomendasi

Tahap terakhir adalah memberikan rekomendasi perbaikan berdasarkan hasil analisis agar keamanan website dapat ditingkatkan.

3.6 Teknik Analisis Data

Data hasil pengujian yang diperoleh dari OWASP ZAP dianalisis secara deskriptif. Setiap kerentanan yang ditemukan diklasifikasikan berdasarkan standar OWASP Top 10 dan tingkat risikonya (*Low, Medium, High*, atau *Critical*). Selanjutnya dilakukan pembahasan mengenai penyebab kerentanan serta rekomendasi perbaikan yang dapat diterapkan untuk meningkatkan keamanan website.

BAB IV

HASIL DAN PEMBAHASAN

4.1 Pelaksanaan Pengujian

Pengujian keamanan website Ktown4u dilakukan menggunakan aplikasi OWASP ZAP pada sistem operasi Windows 11 dengan browser Google Chrome. Pengujian dilakukan melalui fitur Automated Scan yang terdiri atas proses Spider Scan, Passive Scan, dan Active Scan. Sebelum proses scanning dilakukan, browser telah dikonfigurasi agar seluruh aktivitas HTTP dan HTTPS melewati proxy OWASP ZAP sehingga setiap request dan response dapat direkam serta dianalisis.

Target pengujian merupakan halaman publik website Ktown4u yang dapat diakses tanpa melakukan login maupun perubahan data. Pengujian dilakukan hanya untuk tujuan akademik sehingga tidak melakukan eksploitasi yang dapat mengganggu layanan website.

4.2 Hasil Passive Scan

Passive Scan dilakukan secara otomatis ketika website diakses. Pada tahap ini OWASP ZAP menganalisis setiap request dan response tanpa melakukan perubahan terhadap website.

Beberapa temuan yang diperoleh antara lain:

No	Jenis Kerentanan	Risk
1	Missing Security Headers	Low
2	Content Security Policy Not Set	Medium
3	Server Information Disclosure	Low
4	Information Disclosure melalui Header	Low

Temuan tersebut menunjukkan bahwa website masih memiliki beberapa konfigurasi keamanan yang dapat ditingkatkan meskipun belum menunjukkan adanya kerentanan kritis.

4.3 Hasil Active Scan

Active Scan dilakukan untuk menguji kemungkinan adanya kerentanan yang dapat dieksploitasi pada website.

Berdasarkan hasil scanning menggunakan OWASP ZAP, ditemukan beberapa alert yang memiliki tingkat risiko Low dan Medium. Selama proses pengujian tidak ditemukan kerentanan dengan tingkat High maupun Critical.

Ringkasan hasil Active Scan ditunjukkan pada tabel berikut.

Tingkat Risiko	Jumlah
Critical	0
High	0
Medium	2
Low	4
Informational	Beberapa

Hasil tersebut menunjukkan bahwa secara umum website memiliki tingkat keamanan yang cukup baik, namun masih terdapat beberapa konfigurasi keamanan yang perlu diperbaiki.

4.4 Analisis Berdasarkan OWSP TOP 10

Seluruh hasil scanning kemudian dipetakan ke dalam kategori OWASP Top 10 (2021).

OWASP Top 10	Hasil
Broken Access Control	Tidak ditemukan
Cryptographic Failures	Tidak ditemukan
Injection	Tidak ditemukan
Insecure Design	Tidak ditemukan
Security Misconfiguration	Ditemukan
Vulnerable and Outdated Components	Tidak ditemukan
Identification and Authentication Failures	Tidak ditemukan
Software and Data Integrity Failures	Tidak ditemukan
Security Logging and Monitoring Failures	Tidak ditemukan
Server Side Request Forgery	Tidak ditemukan

Berdasarkan tabel tersebut, sebagian besar alert yang ditemukan termasuk ke dalam kategori Security Misconfiguration. Kerentanan tersebut umumnya disebabkan oleh konfigurasi header keamanan yang belum lengkap.

4.5 Pembahasan

Berdasarkan hasil pengujian menggunakan OWASP ZAP dapat diketahui bahwa website Ktown4u telah menerapkan beberapa mekanisme keamanan yang cukup baik. Hal ini terlihat dari tidak ditemukannya kerentanan dengan tingkat risiko High maupun Critical.

Namun demikian, masih terdapat beberapa konfigurasi keamanan yang perlu ditingkatkan, terutama berkaitan dengan HTTP Security Header seperti Content Security Policy (CSP), X-Frame-Options, X-Content-Type-Options, dan beberapa header keamanan lainnya.

Penerapan header-header tersebut dapat meningkatkan perlindungan terhadap berbagai jenis serangan seperti Clickjacking, Cross Site Scripting (XSS), serta Information Disclosure.

Selain itu, administrator website disarankan untuk melakukan vulnerability assessment secara berkala agar setiap perubahan konfigurasi maupun penambahan fitur baru tetap memenuhi standar keamanan OWASP.

BAB V

PENUTUP

5.1 Kesimpulan

Berdasarkan hasil penelitian yang telah dilakukan mengenai Analisis Vulnerability Assessment dan Penetration Testing pada Website Ktown4u Menggunakan OWASP ZAP Berdasarkan Standar OWASP Top 10, dapat diambil beberapa kesimpulan sebagai berikut.

1. Pengujian keamanan website Ktown4u berhasil dilakukan menggunakan aplikasi OWASP ZAP melalui tahapan *Information Gathering*, *Spider Scan*, *Passive Scan*, dan *Active Scan*. Seluruh tahapan tersebut mampu memberikan informasi mengenai kondisi keamanan website secara umum.
2. Berdasarkan hasil pemindaian, ditemukan beberapa kerentanan dengan tingkat risiko Low dan Medium yang sebagian besar berkaitan dengan konfigurasi keamanan website, seperti belum optimalnya penerapan HTTP Security Header. Tidak ditemukan kerentanan dengan tingkat risiko High maupun Critical pada pengujian yang dilakukan.
3. Hasil analisis berdasarkan standar OWASP Top 10 (2021) menunjukkan bahwa sebagian besar temuan termasuk ke dalam kategori Security Misconfiguration. Kondisi tersebut menunjukkan bahwa website telah memiliki mekanisme keamanan yang cukup baik, namun masih memerlukan beberapa penyempurnaan konfigurasi agar tingkat keamanannya semakin optimal.
4. Rekomendasi yang diberikan antara lain menambahkan Content Security Policy (CSP), melengkapi HTTP Security Header, melakukan pembaruan sistem secara berkala, serta melaksanakan pengujian keamanan secara rutin menggunakan OWASP ZAP sebagai langkah pencegahan terhadap potensi ancaman keamanan di masa mendatang.

5.2 Saran

Berdasarkan hasil penelitian yang telah dilakukan, penulis memberikan beberapa saran sebagai berikut.

1. Pengelola website Ktown4u disarankan untuk melakukan evaluasi keamanan secara berkala agar setiap perubahan pada sistem tetap memenuhi standar keamanan aplikasi web.
2. Konfigurasi keamanan website perlu ditingkatkan, terutama pada penerapan HTTP Security Header, Content Security Policy (CSP), dan mekanisme perlindungan lainnya sesuai dengan rekomendasi OWASP Top 10.

3. Penelitian selanjutnya dapat menggunakan kombinasi beberapa tools keamanan, seperti Burp Suite, Nmap, Nikto, atau SQLMap, sehingga hasil analisis menjadi lebih lengkap.
4. Penelitian berikutnya juga dapat membandingkan hasil pengujian beberapa website e-commerce sehingga diperoleh gambaran mengenai tingkat keamanan website berdasarkan objek penelitian yang berbeda.

DAFTAR PUSTAKA

- [1] OWASP Foundation, *OWASP Top 10: The Ten Most Critical Web Application Security Risks*, 2021. [Online]. Available: <https://owasp.org/Top10/2021/>. [Accessed: Jul. 6, 2026].
- [2] OWASP Foundation, *OWASP Zed Attack Proxy (ZAP) Documentation*, 2024. [Online]. Available: [OWASP ZAP Official Website](#). [Accessed: Jul. 6, 2026].
- [3] D. Stuttard and M. Pinto, *The Web Application Hacker's Handbook: Finding and Exploiting Security Flaws*, 2nd ed. Indianapolis, IN, USA: Wiley Publishing, 2011.
- [4] W. Stallings, *Network Security Essentials: Applications and Standards*, 7th ed. New York, NY, USA: Pearson, 2020.
- [5] NIST, *Technical Guide to Information Security Testing and Assessment (SP 800-115)*. Gaithersburg, MD, USA: National Institute of Standards and Technology, 2008.
- [6] R. S. Pressman and B. R. Maxim, *Software Engineering: A Practitioner's Approach*, 9th ed. New York, NY, USA: McGraw-Hill Education, 2020.
- [7] I. Sommerville, *Software Engineering*, 10th ed. Boston, MA, USA: Pearson, 2016.
- [8] R. Rahman and D. F. Razak, "Pengujian Penetrasi Jaringan Menggunakan OWASP ZAP dan SQLMap untuk Mengidentifikasi Kerentanan Keamanan Website," *Jurnal Informatika*, vol. 11, no. 2, pp. 112–121, 2024.
- [9] R. Rohmaniah, dkk., "Enhancing Website Security Using Vulnerability Assessment and Penetration Testing," *Journal of Information Security*, vol. 6, no. 1, pp. 45–55, 2024.
- [10] Zahrani, dkk., "Analisis Vulnerability Assessment pada Sistem Informasi Website IITC Intermedia Universitas Amikom Purwokerto Menggunakan OWASP ZAP," *Jurnal Teknologi Informasi*, vol. 8, no. 2, pp. 73–82, 2024.
- [11] K. Muhammad Najib Dwi Satria, "Vulnerability Analysis of SMAN 1 Banjar Agung Website Using OWASP ZAP," *International Journal of Computer Science and Information Technology*, vol. 5, no. 1, pp. 18–27, 2025.
- [12] H. W. Maulana, dkk., "Penetration Testing untuk Menguji Sistem Keamanan Website Menggunakan OWASP ZAP," *Jurnal Sistem Informasi dan Teknologi Informasi*, vol. 9, no. 1, pp. 51–61, 2025.
- [13] P. Sane, "Is the OWASP Top 10 List Comprehensive Enough for Writing Secure Code?," *arXiv preprint arXiv:2002.11269*, 2020.
- [14] R. Ventura, D. J. Franco, and O. K. Akram, "A Novel VAPT Algorithm: Enhancing Web Application Security Through OWASP Top 10 Optimization," *arXiv preprint arXiv:2311.10450*, 2023.
- [15] M. Bach-Nutman, "Understanding the Top 10 OWASP Vulnerabilities," *arXiv preprint arXiv:2012.09960*, 2020.

